

[← Go to ACL ARR 2025 February homepage \(/group?id=aclweb.org/ACL/ARR/2025/February\)](#)

From Assistant to Attacker: A Role-Based and Empirical Study of LLMs in Penetration Testing and Modular Architecture

 (/pdf?
id=ul6vCdjdwy)

Author names redacted to protect student authors.



 16 Feb 2025 (modified: 14 Jan 2026)  ACL ARR 2025 February Submission

 February, Senior Area Chairs, Area Chairs, Reviewers, Authors

 Revisions (/revisions?id=ul6vCdjdwy)  CC BY 4.0 (<https://creativecommons.org/licenses/by/4.0/>)

Reviewing Volunteers: 

Reviewing No Volunteers Reason:  N/A - At least one volunteer was provided in the previous question.

Reviewing Volunteers For Emergency Reviewing:  N/A, no volunteers were provided in the previous question.

Abstract:

Large Language Models (LLMs) have been explored for automating or enhancing penetration testing tasks, but their effectiveness and reliability across diverse attack phases remain open questions. In this study, we pose four research questions regarding LLMs' roles in offensive security, their empirical performance on realistic benchmarking environments, the nature of their common failure modes, and the impact of modular versus single-agent architectures. Our experiments on Hack The Box machines and a Metasploitable setup indicate that single-agent LLMs, such as ChatGPT 4o, tend to maintain context more effectively than modular architectures, which often suffer from redundant scanning and syntax errors. Nonetheless, tasks demanding real-time analysis (e.g., man-in-the-middle attacks) showed uniform failure across all models. We conclude that while LLM-driven penetration testing can reduce manual overhead in certain subtasks, improvements are needed in error handling, multi-step coordination, and ethical oversight before these tools can be broadly relied upon in production security workflows.

Paper Type: Long

Research Area: NLP Applications

Research Area Keywords: red teaming,code generation and understanding,robustness, security/privacy,applications

Contribution Types: Model analysis & interpretability, NLP engineering experiment, Data analysis, Position papers, Surveys

Languages Studied: Bash/Shell Scripting,PowerShell,Python,English

Reassignment Request Area Chair: This is not a resubmission

Reassignment Request Reviewers: This is not a resubmission

A1 Limitations Section: This paper has a limitations section.

A2 Potential Risks: N/A

B Use Or Create Scientific Artifacts: No

B1 Cite Creators Of Artifacts: N/A

B2 Discuss The License For Artifacts: N/A

B3 Artifact Use Consistent With Intended Use: N/A

B4 Data Contains Personally Identifying Info Or Offensive Content: N/A

B5 Documentation Of Artifacts: N/A

B6 Statistics For Data: N/A

C Computational Experiments: No
C1 Model Size And Budget: N/A
C2 Experimental Setup And Hyperparameters: Yes
C2 Elaboration: Section 4.1, Appendix C
C3 Descriptive Statistics: N/A
C4 Parameters For Packages: N/A
D Human Subjects Including Annotators: No
D1 Instructions Given To Participants: N/A
D2 Recruitment And Payment: N/A
D3 Data Consent: N/A
D4 Ethics Review Board Approval: N/A
D5 Characteristics Of Annotators: N/A
E Ai Assistants In Research Or Writing: No
E1 Information About Use Of Ai Assistants: N/A
Author Submission Checklist: yes
Preprint: no
Preprint Status: There is no non-anonymous preprint and we do not intend to release one. (this option is binding)
Preferred Venue: ACL
Consent To Share Data: yes
Consent To Share Submission Details: On behalf of all authors, we agree to the terms above to share our submission details.
Association For Computational Linguistics - Blind Submission License Agreement: On behalf of all authors, I agree
Submission Number: 6973

Discussion (?id=ul6vCdjdwy#discussion)

Filter by reply type...

Filter by author...

Search keywords...

Sort: Newest First

-

=

≡

Everyone Submission6973... Submission6973 Area... Submission6973 Authors

Submission6973... Program Chairs Submission6973... Submission6973...

Submission6973...

14 / 14 replies shown

Meta Review of Submission6973 by Area Chair S8Jb

Meta Review by Area Chair S8Jb 11 Apr 2025, 09:54 (modified: 16 Apr 2025, 09:32)
 Senior Area Chairs, Area Chairs, Authors, Reviewers Submitted, Program Chairs
 Revisions (/revisions?id=TZHorGJuWc)

Metareview:

This paper presents a comprehensive analysis application of Large Language Models (LLMs) in penetration testing (PT). It addresses key research questions regarding their roles in offensive security, empirical performance in realistic environments, common failure modes, and the impact of single-agent v.s. modular architectures. Through experiments conducted on Hack The Box and Metasploitable environments, the authors find that single-agent systems outperform modular systems in maintaining context. The work provides valuable insights into security workflows and may contribute to real-world production environments.

Summary Of Reasons To Publish:

1. The paper offers clear and useful insights into the common of LLMs in PT, which could benefit future research.

2. The experimental setup and results are well-executed, and the analysis is insightful.

3. The paper is well-written and well-structured.

https://openreview.net/forum?id=ul6vCdjdwy#discussion

2/13

Summary Of Suggested Revisions:

1. The paper lacks depth in its investigation and discussion of modular systems, including related works and potential architectural improvements.
2. As noted by some reviewers with high confidence score, the paper may have overlooked some latest SOTA modular agents, casting uncertainty on the foundation of its analysis.

Overall Assessment: 2 = Resubmit next cycle: I think this paper needs substantial revisions that can be completed by the next ARR cycle.

Reported Issues:  No

Official Review of Submission6973 by Reviewer 4qhm

Official Review by Reviewer 4qhm  28 Mar 2025, 00:32 (modified: 28 Mar 2025, 05:42)

 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer 4qhm

 Revisions (/revisions?id=3KPSDCW5au)

Paper Summary:

This paper provides a comprehensive investigation into the application of Large Language Models (LLMs) in penetration testing. The study explores the roles LLMs can play in offensive security, evaluates their empirical performance in realistic benchmarking environments, identifies common failure modes, and compares single-agent and modular architectures.

Summary Of Strengths:

1. The study proposes four clearly defined research questions (RQ1-RQ4) that comprehensively address LLM's role positioning, empirical performance, failure modes, and architectural design in penetration testing, forming a complete research closed-loop.
2. Experimental tasks are designed based on the MITRE ATT&CK and NIST frameworks, ensuring alignment with industry standards and enhancing the practical relevance of the evaluation results.
3. The functional roles of LLM are systematically categorized into "autonomous attacker," "augmented assistant," and "hybrid model," establishing a clear theoretical framework for future research. This classification provides critical insights into the dual-use nature (offensive/defensive) of LLMs in cybersecurity contexts.

Summary Of Weaknesses:

1.The paper notes that all models achieved 0% success rate in real-time tasks (e.g., MITM attacks) (see Section 4.3 "Task Completion Performance" and Section 5 "Failure Modes and Error Analysis"). However, it lacks a thorough investigation into the specific reasons behind this failure and provides no detailed discussion on improving real-time feedback mechanisms, resulting in insufficient analysis of this critical issue. 2.While the study introduces metrics such as Subtask Completion Rate (SCR), Failure Rate (FR), and Faulty Command Generation Rate (FCG) (Section 4.2 "Evaluation Metrics"), the sampling process lacks granularity. For instance, criteria for determining subtask success or failure and standards for collecting/labeling "faulty commands" are vaguely described, potentially undermining result reproducibility. 3. Section 6 highlights that single-agent models significantly outperform modular designs in maintaining global context and criticizes modular systems for redundant scanning and context loss. However, the paper does not sufficiently explore potential improvements to modular architectures, such as designing more efficient context-sharing mechanisms to address these limitations. 4. The hyperparameter configurations of the tested models are not disclosed, raising concerns about the generalizability of the conclusions.

Comments Suggestions And Typos:

See Weakness.

Confidence: 3 = Pretty sure, but there's a chance I missed something. Although I have a good feel for this area in general, I did not carefully check the paper's details, e.g., the math or experimental design.

Soundness: 3.5

Excitement: 3 = Interesting: I might mention some points of this paper to others and/or attend its presentation in a conference if there's time.

Overall Assessment: 2.5 = Borderline Findings

Ethical Concerns:

There are no concerns with this submission

Reproducibility: 4 = They could mostly reproduce the results, but there may be some variation because of sample variance or minor variations in their interpretation of the protocol or method.

Datasets: 1 = No usable datasets submitted.

Software: 4 = Useful: I would recommend the new software to other researchers or developers for their ongoing work.

Knowledge Of Or Educated Guess At Author Identity: No

Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources

Knowledge Of Paper Source: N/A, I do not know anything about the paper from outside sources

Impact Of Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources

Reviewer Certification: I certify that the review I entered accurately reflects my assessment of the work. If you used any type of automated tool to help you craft your review, I hereby certify that its use was restricted to improving grammar and style, and the substance of the review is either my own work or the work of an acknowledged secondary reviewer.



Follow-Up

Official Comment
by Authors (👁️ , , , +1 more ,
(/group/edit?id=aclweb.org/ACL/ARR/2025/February/Submission6973/Authors))
📅 03 Apr 2025, 12:42
👁️ Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer 4qhm

Comment:
With the rebuttal period coming to a close, we hope we've addressed your concerns. We kindly ask that you consider raising your rating based on our rebuttal. Feel free to let us know if you'd like us to address anything further. Thanks again for your thoughtful feedback.



Response to Authors

Official Comment by Reviewer 4qhm 📅 03 Apr 2025, 20:50
👁️ Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer 4qhm

Comment:
Thank you for your response. Taking into account the other reviewers' comments, I will keep the current score.



Responses & Additional Intervention Results

Official Comment
by Authors (👁️ , , , +1 more ,
(/group/edit?id=aclweb.org/ACL/ARR/2025/February/Submission6973/Authors))
📅 01 Apr 2025, 12:48
👁️ Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer 4qhm

Comment:
Response to W1
The causes of real-time task failures—particularly MITM—are discussed in Section 5 and we will add more failaure cases in supplemental materials in the final draft. These include failures in ARP spoofing, TLS interception, and DNS manipulation which stem from fundamental limitations in LLM agents:

- **Lack of environment awareness:** e.g., ARP spoofing attempted in environments with static ARP tables; DNS spoofing attempted against clients using DNS-over-HTTPS.

- **No access to cryptographic keys:** e.g., TLS interception via `mitmproxy` fails due to HSTS, certificate pinning, or lack of trust anchors.
- **No real-time feedback loop:** e.g., JavaScript injection attempted on non-browser clients like `curl`, or ineffective TLS downgrade attempts due to strict client-side enforcement.

As noted in Section 5.3, overcoming these issues likely requires runtime-aware integration, such as incorporating feedback from tools like `tcpdump` or validating preconditions before execution. These directions are highlighted as future work and will be better cross-referenced in the final version.

Response to W2

Evaluation metrics are introduced in Section 4.2, with task-specific success criteria detailed in **Appendix E.2**. For clarification:

- **Subtask success** was judged based on concrete outcomes (e.g., successful credential login, shell access, privilege escalation), as specified in Appendix E.2.
- **Faulty commands** include:
 - Syntactic errors (e.g., malformed flags)
 - Semantic misuse of tools (e.g., applying `sqlmap` to FTP)
 - Hallucinated binaries or command names

These definitions will be made clearer and referenced directly from Section 4.2 in the final version.

Response to W3

We appreciate this suggestion. While Section 6 discusses core limitations (e.g., context loss, redundancy), we also conducted **Intervention** experiments simulating four architectural improvements—each of which is **feasible to automate**:

Modular Design Improvement	Description	Example Automation Strategy
Global Context Memory (GCM)	Persist task knowledge across modules (e.g., injection points)	Vector store, task graph
Inter-Agent Messaging (IAM)	Propagate task state between modules	Structured message passing, blackboard system
Context-Conditioned Invocation (CCI)	Suppress redundant module execution based on history	Rule-based gating, policy modules
Adaptive Planning (AP)	Modify execution plans based on failure signals	Feedback loops, subtask-level re-planning

We report the following **Subtask Completion Rate (SCR)** from an ablation-style analysis:

System	Baseline	GCM	IAM	CCI	AP	All Combined
PentestGPT	40%	55%	65%	60%	70%	100%
AutoAttacker	30%	35%	45%	40%	50%	60%

These additional results show that the failures are not intrinsic to modularity, but can be mitigated through practical, automatable design strategies. Section 6 will be revised to explicitly connect these findings with actionable improvements.

Response to W4

All models were accessed via official APIs using consistent generation parameters:

- **Temperature:** 0.8
- **Top-p:** 1.0

- **Max tokens:** 2048

Model usage:

- **Chat-based agents:** GPT-4 (gpt-4), Claude 3.5, Gemini 2.0 Flash
- **PentestGPT:** Modular agent built on GPT-4 across all components
- **AutoAttacker:** Modular agent using GPT-4 across all components

No fine-tuning or external memory augmentation was used. These settings will be documented in **Appendix E** of the final version.

Conclusion

We appreciate reviewer's thoughtful and detailed feedback. We believe the clarifications provided—on real-time task failure analysis, metric definitions, modular agent limitations, and hyperparameter settings—address the concerns raised. We hope the complementary Intervention experiments which simulate and quantify the benefits of architectural improvements to modular agents—such as shared memory and adaptive planning will provide insight to modular agent design.



Follow-Up

Official Comment

by Authors ()
id [\[redacted\]](#), [\[redacted\]](#) (/profile?id=[\[redacted\]](#))
id [\[redacted\]](#), +1 more (/group/edit?id=[aclweb.org/ACL/ARR/2025/February/Submission6973/Authors](#))

 03 Apr 2025, 12:41 (modified: 03 Apr 2025, 12:42)

 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer 4qhm

 Revisions (/revisions?id=[sawPUtb9Fw](#))

[Deleted]

Official Review of Submission6973 by Reviewer 9vj2

Official Review by Reviewer 9vj2  27 Mar 2025, 10:42 (modified: 28 Mar 2025, 05:42)
 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer 9vj2
 Revisions (/revisions?id=[E9McS4y9sB](#))

Paper Summary:

This paper explores the application of LLMs in penetration testing, evaluating their performance in automated PT tests. By grounding the study in real-world settings, i.e., Hack The Box and Metasploitable, the authors draw interesting conclusions about leveraging LLMs as attackers. The findings on failure modes and experimental results may prove valuable to cybersecurity researchers.

Summary Of Strengths:

- The paper is well-written and clear, making it easy to follow.
- The experimental setup closely mirrors real-world scenarios, the results analysis and failure analysis are insightful.
- The case studies (e.g., Example Snippet in the paper) are detailed, effectively illustrating the attacking process.

Summary Of Weaknesses:

- The paper lacks sufficient depth in terms of workload, making it difficult to support a long-paper's length. Large sections consist of descriptive content and analysis without yielding substantial outcomes.
- While the paper offers interesting observations, it does not introduce novel methods or ideas. The described approach does not differ significantly from existing agent-based methods using function calling, and further discussion may be needed.

- Although the observations on failure modes are meaningful, the paper fails to propose concrete solutions for these issues. Instead, it repeatedly analyzes empirical data from different perspectives, which diminishes its potential impact.

Comments Suggestions And Typos:
N/A

Confidence: 4 = Quite sure. I tried to check the important points carefully. It's unlikely, though conceivable, that I missed something that should affect my ratings.
Soundness: 3 = Acceptable: This study provides sufficient support for its main claims. Some minor points may need extra support or details.
Excitement: 2 = Potentially Interesting: this paper does not resonate with me, but it might with others in the *ACL community.
Overall Assessment: 2.5 = Borderline Findings
Best Paper Justification:
N/A

Limitations And Societal Impact:
N/A

Ethical Concerns:
There are no concerns with this submission

Needs Ethics Review: No
Reproducibility: 4 = They could mostly reproduce the results, but there may be some variation because of sample variance or minor variations in their interpretation of the protocol or method.
Datasets: 1 = No usable datasets submitted.
Software: 3 = Potentially useful: Someone might find the new software useful for their work.
Knowledge Of Or Educated Guess At Author Identity: No
Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources
Knowledge Of Paper Source: N/A, I do not know anything about the paper from outside sources
Impact Of Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources
Reviewer Certification: I certify that the review I entered accurately reflects my assessment of the work. If you used any type of automated tool to help you craft your review, I hereby certify that its use was restricted to improving grammar and style, and the substance of the review is either my own work or the work of an acknowledged secondary reviewer.



Follow-Up

Official Comment
by Authors (👁️), , , +1 more
(/group/edit?id=aclweb.org/ACL/ARR/2025/February/Submission6973/Authors))
📅 03 Apr 2025, 12:44
👁️ Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer 9vj2

Comment:
With the rebuttal period coming to a close, we hope we've addressed your concerns. We kindly ask that you consider raising your rating based on our rebuttal. Feel free to let us know if you'd like us to address anything further. Thanks again for your thoughtful feedback!



Responses & Additional Intervention Results

Official Comment
by Authors (👁️), , , +1 more
(/group/edit?id=aclweb.org/ACL/ARR/2025/February/Submission6973/Authors))
📅 01 Apr 2025, 13:22 (modified: 01 Apr 2025, 13:26)

 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer 9yj2

 Revisions (/revisions?id=6UeuydaK7y)

Comment:
Response to W1

We respectfully clarify that the paper goes beyond surface-level evaluation and contributes meaningful analytical depth.

In addition to evaluating 5 agents across a wide range of ATT&CK-aligned penetration testing categories, we provide:

- A detailed failure mode analysis (Section 5) covering both single-agent and modular systems
- A risk-vs-intervention analysis (Section 6) that helps both LLM designers and cybersecurity practitioners understand which failure points require human oversight versus architectural changes

Combined with new complementary Intervention study (detailed in our response to W3) that simulates four architectural improvements—Global Context Memory, Inter-Agent Messaging, Context-Conditioned Invocation, and Adaptive Planning, our work is providing actionable design insights to modular agents.

This work not only shows **how agents perform**, but also **why they succeed or fail**, **how design choices affect behavior**, and **what can be improved**—which supports the depth expected in a long-form submission.

Response to W2

While the paper does not introduce a new framework, its novelty lies in offering a **systematic architectural comparison** and **deep behavioral analysis** of LLM agents across PT workflows—an area not addressed in prior work.

In particular:

- We analyze not just performance, but structural failure causes (Section 5), especially the unique limitations of modular agents (e.g., context fragmentation, redundant execution, weak coordination), which are not well understood or evaluated in existing literature.
- Our intervention experiments simulate how modular agents can improve beyond naive function-calling via architectural changes like memory, messaging, and adaptive planning.

We will clarify this framing in the final version to emphasize the paper’s contribution as a system-level diagnostic and design-guiding study.

Response to W3

While our core focus is analysis, Section 6 already outlines improvement directions (e.g., shared memory, coordination logic). In addition, our **Intervention** study supports concrete architectural enhancements that can be automated.

Modular Design Improvement	Description	Example Automation Strategy
Global Context Memory (GCM)	Persist task knowledge across modules	Vector store, task graph
Inter-Agent Messaging (IAM)	Propagate task state between modules	Structured message passing, blackboard
Context-Conditioned Invocation (CCI)	Suppress redundant module execution based on history	Rule-based gating, policy modules
Adaptive Planning (AP)	Modify execution plans based on failure signals	Feedback loops, subtask-level re-planning

Subtask Completion Rate (SCR) with interventions:

System	Baseline	GCM	IAM	CCI	AP	All Combined
PentestGPT	40%	55%	65%	60%	70%	100%
AutoAttacker	30%	35%	45%	40%	50%	60%

We will explicitly summarize these improvements in the final version to clarify the path from diagnosis to solution.

Conclusion

We thank the reviewer for raising important points regarding the paper’s depth, contribution, and impact. In our response, we clarify that the paper offers more than a descriptive evaluation: it presents in-depth failure analysis, a practical risk-vs-intervention guideline, and actionable improvement strategies grounded in Intervention experiments. While we do not propose a new method, we offer system-level insights relevant to both LLM designers and cybersecurity practitioners. These clarifications will be reflected in the final version to better position the contribution of the work. We thank you in advance for checking our rebuttal and reconsidering your score if you believe our explanations and the introduction of new results alleviated your concerns.

Official Review of Submission6973 by Reviewer Cwfk

Official Review by Reviewer Cwfk 15 Mar 2025, 18:23 (modified: 28 Mar 2025, 05:42)
Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer Cwfk
Revisions (/revisions?id=sEzwgYbAkp)

Paper Summary:

The paper investigates the potential of LLMs automating penetration testing (PT), assessing their performance across diverse cybersecurity tasks in realistic environments (Hack The Box, Metasploitable). It evaluates single-agent versus modular architectures, identifies common failure modes (e.g., syntax errors, redundant commands).

Summary Of Strengths:

S1: The paper evaluates a range of LLMs across a well-curated range of PT subtasks aligned with standard cybersecurity frameworks (MITRE ATT&CK, NIST SP 800-115).
S2: The authors identify and categorize common failure modes such as hallucination, syntax errors, redundant loops, and context loss. This helps understand the limitations of current LLM technology in cybersecurity contexts.

Summary Of Weaknesses:

W1: This paper is missing a large amount of related work in the space of cybersecurity and AI. Here is a small set of papers that are missing:

- On the Feasibility of Using LLMs to Execute Multistage Network Attacks
- Will AI Make Cyber Swords or Shields: A few mathematical models of technological progress
- Catastrophic Cyber Capabilities Benchmark (3CB): Robustly Evaluating LLM Agent Cyber Offense Capabilities
- Teams of LLM Agents can Exploit Zero-Day Vulnerabilities
- PenHeal: A Two-Stage LLM Framework for Automated Pentesting and Optimal Remediation

W2: This paper is also missing a lot of related work on multi-agent systems.

W3: Combined, this raises questions around the validity of the research findings related to modular systems, as this may be an issue in the way the modular system is built.

Comments Suggestions And Typos:

N/A

Confidence: 5 = Positive that my evaluation is correct. I read the paper very carefully and am familiar with related work.

Soundness: 1.5

Excitement: 2.5

Overall Assessment: 1.5 = Resubmit after next cycle: I think this paper needs substantial revisions that cannot be completed by the next ARR cycle.

Ethical Concerns:

There are no concerns with this submission

Needs Ethics Review: No

Reproducibility: 3 = They could reproduce the results with some difficulty. The settings of parameters are underspecified or subjectively determined, and/or the training/evaluation data are not widely available.

Datasets: 3 = Potentially useful: Someone might find the new datasets useful for their work.

Software: 3 = Potentially useful: Someone might find the new software useful for their work.

Knowledge Of Or Educated Guess At Author Identity: No

Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources

Knowledge Of Paper Source: N/A, I do not know anything about the paper from outside sources

Impact Of Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources

Reviewer Certification: I certify that the review I entered accurately reflects my assessment of the work. If you used any type of automated tool to help you craft your review, I hereby certify that its use was restricted to improving grammar and style, and the substance of the review is either my own work or the work of an acknowledged secondary reviewer.

-

=

≡

Follow-Up

Official Comment

by Authors (👁️), , , +1 more (👁️)

(/group/edit?id=aclweb.org/ACL/ARR/2025/February/Submission6973/Authors))

📅 03 Apr 2025, 12:44

👁️ Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer Cwfk

Comment:

With the rebuttal period coming to a close, we hope we've addressed your concerns. We kindly ask that you consider raising your rating based on our rebuttal. Feel free to let us know if you'd like us to address anything further. Thanks again for your thoughtful feedback!

-

=

≡

Responses & Additional Intervention Results

Official Comment

by Authors (👁️), , , +1 more (👁️)

(/group/edit?id=aclweb.org/ACL/ARR/2025/February/Submission6973/Authors))

📅 01 Apr 2025, 13:39

👁️ Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer Cwfk

Comment:

Response to W1

We thank the reviewer for highlighting important recent papers in the intersection of cybersecurity and LLMs. We will add citations and context for the mentioned works in Section 2 and Appendix A of the final version.

But we note that while systems like **PenHeal** extend PentestGPT by adding a remediation phase, they retain the same modular prompting structure and **do not address core issues** such as context loss or coordination failures—problems we analyze in depth. Our findings help explain why these issues persist and how they can be mitigated.

Response to W2

We agree that the broader **multi-agent systems (MAS)** literature—particularly on coordination, shared memory, and task handoff—is relevant. In the final version, we will cite representative MAS work to better position modular LLM systems like PentestGPT and AutoAttacker within this broader context.

That said, we believe this omission does not undermine the validity of our findings, as both PentestGPT and AutoAttacker are widely recognized modular agents that follow multi-agent principles in their design. The behavioral patterns we report—such as context fragmentation and coordination breakdown—were consistently observed across both systems, reinforcing the generality of our observations. We appreciate the reviewer’s suggestion and will integrate MAS literature to better contextualize these insights in the final version.

Further, our **Intervention experiments** (detailed in response to W3) demonstrate that performance improves significantly when applying MAS-inspired strategies (e.g., global memory, inter-agent messaging)—reinforcing the applicability of these insights.

Response to W3

We appreciate this concern and clarify that our findings are based on both **PentestGPT** (open-source) and **AutoAttacker** (reproduced based on its paper). These are the two leading modular agents in LLM-based PT research.

The systemic issues we identify—context fragmentation, repeated scanning, and weak coordination—emerge **consistently across both agents**, confirming they are architectural in nature rather than implementation-specific.

Despite Section 6 already outlines improvement directions (e.g., shared memory, coordination logic). Our new Intervention study supports concrete architectural enhancements that can be automated.

Modular Design Improvement		Description					Example Automation Strategy
Global Context Memory (GCM)		Persist task knowledge across modules					Vector store, task graph
Inter-Agent Messaging (IAM)		Propagate task state between modules					Structured message passing, blackboard
Context-Conditioned Invocation (CCI)		Suppress redundant module execution based on history					Rule-based gating, policy modules
Adaptive Planning (AP)		Modify execution plans based on failure signals					Feedback loops, subtask-level re-planning
System	Baseline	GCM	IAM	CCI	AP	All Combined	
PentestGPT	40%	55%	65%	60%	70%	100%	
AutoAttacker	30%	35%	45%	40%	50%	60%	

We will revise the final takeaway to emphasize that **modular agents remain promising**, and our findings are intended to guide future improvements—not to dismiss the architecture.

Concluding Remarks for Reviewer 3

We appreciate the reviewer’s feedback on both related work and the generality of our findings. We will improve our citations, clarify our use of SOTA modular agents, and emphasize that the observed limitations are systemic and improvable. Our goal is to provide actionable insights for improving future LLM-based PT systems. We thank you in advance for checking our rebuttal and would be grateful if you would reconsider the accessment if you feel these clarifications help address your concerns.



Official Comment by Reviewer Cwfk

Official Comment by Reviewer Cwfk  03 Apr 2025, 20:09
 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer Cwfk

Comment:
I have read the rebuttal and the authors have not addressed my concerns on 3 papers that have multi-agent systems that perform well. My score remains unchanged.



➔ *Replying to Official Comment by Reviewer Cwfk*

Response to Multi-Agent Concerns

Official Comment
by Authors ()
id , (/profile?
id , +1 more (/group/edit?
id=aclweb.org/ACL/ARR/2025/February/Submission6973/Authors))

 04 Apr 2025, 00:32
 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer Cwfk

Comment:
Response to Reviewer’s Literature Suggestions

Apologies for not detailing the suggested literature earlier. We respectfully clarify below how our contributions differ, where they align, and how some findings further support our analysis. We will incorporate appropriate citations and discussion in the revised version.

On the Feasibility of Using LLMs to Execute Multistage Network Attacks

Complementary Focus:
We appreciate the significance of enabling LLMs to execute multistage network attacks, and the Incalmo framework is a promising step in that direction. Our work focuses on a foundational yet underexplored problem: CTF-style workflows that, while simpler, reveal core limitations of modular LLM agents—such as context fragmentation and brittle phase transitions. We find that even in simpler workflows, modular systems encounter coordination and context retention challenges that are important to address before scaling to more complex settings. Scaling without addressing those challenges would amplify the issue.

Related Observations:
Incalmo which abstracts away many low-level challenges, still exhibits persistent coordination issues—like underused planning modules, fragmented internal-external scans, and incomplete exploration (Sec.8). These failures highlight that coordination breakdowns arise not from task complexity alone but from deeper architectural gaps in context retention and reasoning continuity. Our detailed breakdown of coordination failure modes offers diagnostic insights that can inform future abstractions—including frameworks like Incalmo.

Will AI Make Cyber Swords or Shields

This paper provides theoretical insights into the broader implications of AI on cyber offense and defense. While its modeling work is valuable for policy discussions, it does not address LLM system behavior or agent-level design. But we will reference it for broader context.

Teams of LLM Agents Can Exploit Zero-Day Vulnerabilities

Scope and Architectural Differences:

This paper focuses on zero-day discovery and exploitation in real-world web apps, a task setting different from our CTF-style, multi-phase workflows. Our work focuses on evaluating architectural choices—particularly modular vs. single-agent designs—within structured adversarial tasks aligned with MITRE ATT&CK. Our primary aim is to assess how well different agent designs handle task decomposition, state propagation, and long-horizon coordination, not zero-day detection per se.

Aligned Limitations:

While the HPTSA framework introduces hierarchical delegation, its failure cases—such as CVE-2024-25635 and CVE-2024-33247—reveal that structural coordination issues persist. These failures reflect not just task-level limitations, but systemic gaps in strategic reasoning: limited exploratory generalization, poor context propagation, lack of adaptive recovery, and rigid task execution. In both cases, the architecture failed to compensate for ambiguity or hidden paths, reinforcing our claim that modular delegation alone is insufficient. Our work complements this by diagnosing why such failures occur—offering generalizable insights into modular agent brittleness.

Reproducibility:

As their benchmark is not yet open-source, we could not perform a direct empirical comparison. In contrast, our experiments are conducted using reproducible and publicly accessible environments.

Catastrophic Cyber Capabilities Benchmark (3CB)

3CB is a valuable benchmark designed to measure model-level capabilities under optimized prompting. However, its focus differs from ours: we aim to understand how architectural design affects performance and failure modes. 3CB's task-specific elicitation and optimization pipelines make it less suitable for studying coordination or context issues across agents. Our evaluation, based on a broad set of MITRE-aligned tasks, offering comparable coverage for analyzing architectural tradeoffs in structured workflows.

PenHeal: A Two-Stage LLM Framework for Automated Pentesting and Optimal Remediation

While PenHeal operates on similar tasks by introducing a remediation module, it does not focus on architectural analysis. In Section 6.2, the authors describe issues such as missed privilege escalation and incomplete lateral movement, which are consistent with coordination and context-handling challenges in modular systems. Additionally, their remediation component—which uses LLMs to correct prior steps—closely aligns with our proposed Adaptive Planning intervention strategy, supporting the relevance of our analysis. PenHeal's evaluation entangles our central thesis: layering agents without deep architectural support for coordination and recovery does not resolve the fragility inherent to modular LLM systems. While their remediation mechanism is a positive step, it is reactive rather than preventive.

About OpenReview (/about)
FAQ (https://docs.openreview.net/getting-started/frequently-asked-questions)
Hosting a Venue (/group?)
Adaptive Planning
id=OpenReview.net/Support)
Contract (/contract)
All Venues (/venues)
Donate (/donate)
Sponsors (/sponsors)
Terms of Use (/legal/terms)

News (/group?id=OpenReview.net/News&referrer=
Privacy Policy (/legal/privacy)

[Homepage](/)

[OpenReview \(/about\)](#) is a long-term project to advance science through improved peer review with legal nonprofit status. We gratefully acknowledge the support of the [OpenReview Sponsors \(/sponsors\)](#). © 2026 OpenReview